Institute of Computer Science
CMSC 190: Special Problems · UPLB

Multi-Class Web Payload Classification Using CodeBERT with XAI Explanations

Eljohn Evangelista | Joseph Anthony Hermocilla
Institute of Computer Science, University of the Philippines Los Baños, Laguna, Philippines
eyevangelista1@up.edu.ph | jchermocilla@up.edu.ph

Cybersecurity is underrated. And it causes problems.

context

$4.44M

AVG. BREACH COST (IBM 2025)

4.8M

UNFILLED CYBER ROLES WORLDWIDE

GAP

IN CYBERSECURITY KNOWLEDGE

WAFs are the frontline defense against web attacks. But most rule-based WAFs fail against modern, obfuscated payloads

KNOWN ATTACK

SELECT * FROM users WHERE 1=1

✕ Blocked — matches known SQLi signature

OBFUSCATED ATTACK

SEL%00ECT// * FR%00OM users**

✓ Passes — no signature match

ML models operate as black boxes — we can't trust what we can't understand.

PAYLOAD
'; DROP TABLE--

→

MODEL
? ? ?

→

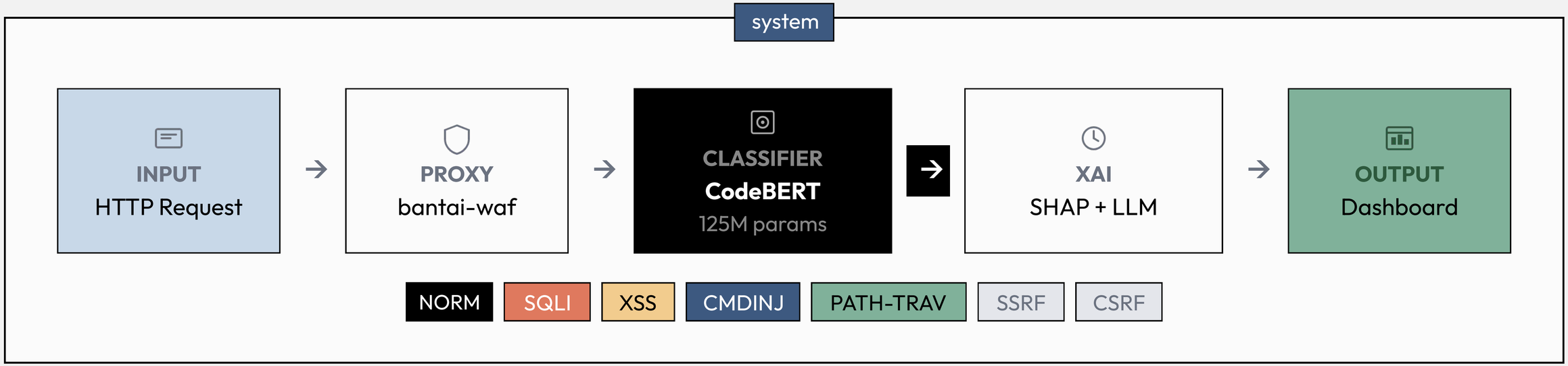
SQLI
97% confidence

PROBLEM
No explanation of which tokens triggered the prediction

PROBLEM
False positives cannot be audited or corrected

PROBLEM
Junior analysts lack the context to verify decisions

The BantAI Pipeline



OBJECTIVES: Train | Classify | Explain | Deploy | Evaluate

Data & Training

training pipeline

Raw Data 38,000 samples	38K
K-Means Dedup 6,366 unique samples	6,366
Tokenize (BPE) 256 max tokens	256
Fine-tune 5 ep. · AdamW · fp16	5 ep.

HYPERPARAMETER	VALUE
Base model	CodeBERT
Parameters	125M
Max tokens	256
Epochs	5
Optimizer	AdamW
Precision	fp16
Classes	7

in-dist results

99.06%
VALIDATION ACCURACY

95.49%
VALIDATION F1-SCORE

0.298247
FINAL TRAIN LOSS

Epoch 5 · 80/10/10 split

Four Evaluation Scenarios

Does BantAI generalize beyond its training distribution?

evaluation design

S1 — **49**

Researcher-Curated Edge Cases

COMPLEX GENERATED PAYLOADS

S2 — **1,830**

EXTERNAL BENCHMARK

GRANANQVIST ML-WAF · OUT-OF-DISTRIBUTION

S3 — **3,000**

YangYang Binary Dataset

EXTERNAL · BINARY LABEL MISMATCH

S4 — **1,517**

Targeted PT / SSRF / CSRF

UNDERREPRESENTED CLASSES · PAYLOADSALLTHETHINGS

S1

Curated Payloads

Strong performance across all 7 classes

93.88%
ACCURACY

0.928
MCC

94.74%
MACRO F1

per-class F1

TABLE VI

PER-CLASS PERFORMANCE: S1 (IN-DISTRIBUTION ABLATION)

Class	Precision	Recall	F1	Support
cmdinj	1.000	1.000	1.000	8
csrf	1.000	1.000	1.000	3
norm	0.875	0.778	0.824	9
path-traversal	0.875	1.000	0.933	7
sqli	1.000	1.000	1.000	8
ssrf	1.000	1.000	1.000	6
xss	0.875	0.875	0.875	8

With $n = 3$–9 samples per class, each misclassification shifts per-class F1 by 10–33 pp, making individual estimates statistically imprecise.

49 researcher-curated edge-case payloads · obfuscated SQLi, XSS, WAF-bypass

S2

Out-of-Distribution Payloads

Generalization boundary exposed

44.66%
MACRO F1 — EXTERNAL BENCHMARK

1,830
SAMPLES · GRANANQVIST ML-WAF

75.63%
ACCURACY

per-class recall

TABLE VII

PER-CLASS PERFORMANCE: S2 (GRANANQVIST ML-WAF)

Class	Precision	Recall	F1	Support
norm	0.811	0.960	0.879	500
sqli	0.972	0.698	0.813	500
xss	0.987	0.762	0.860	500
cmdinj	0.630	0.527	0.574	330

Dominant fail: CMDi → path-traversal confusion · external distribution shift

S3

Binary Classification

Across all scenarios, benign recall remained high

0.962
BENIGN RECALL

0.453
ATTACK RECALL

distr

CLASS	PRECISION	RECALL	F1	SUPPORT
NORM	0.637	0.962	0.767	1500
ATTK	0.923	0.453	0.607	1500
ACCURACY	0.707 (2122 / 3000)			

3,000 samples · Affected by training corpus

S4

Under-represented Classes

Path-traversal generalizes. CSRF is fundamentally limited.

0.959
PATH-TRAVERSAL F1

0.709
SSRF F1

0.683
CSRF F1 — PAYLOAD CEILING

class breakdown

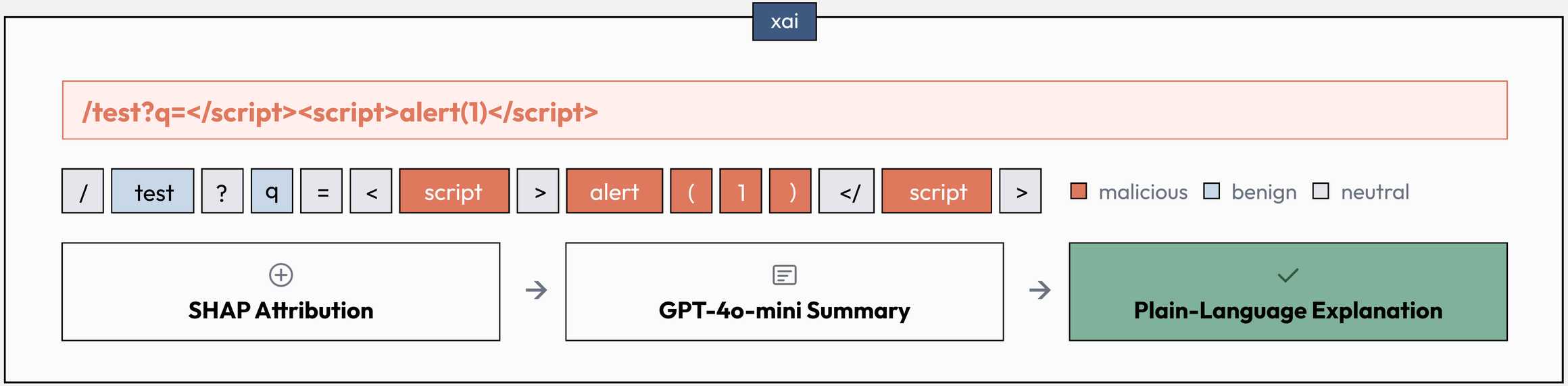
TABLE X

PER-CLASS PERFORMANCE: S4 (TARGETED PT/SSRF/CSRF EVALUATION)

Class	Precision	Recall	F1	Support
norm	0.695	0.960	0.806	500
path-traversal	0.981	0.938	0.959	500
ssrf	0.969	0.559	0.709	440
csrf	0.954	0.533	0.683	77

1,517 samples · PayloadsAllTheThings · DeepakGhengat repo

XAI Explanation Pipeline



SHAP Faithfulness — MDMC Scores

0.3408
CMDI — MOST CONCENTRATED

0.1255
PATH — LOWEST SIGNAL (OTHER THAN NORM)

mdmc by class

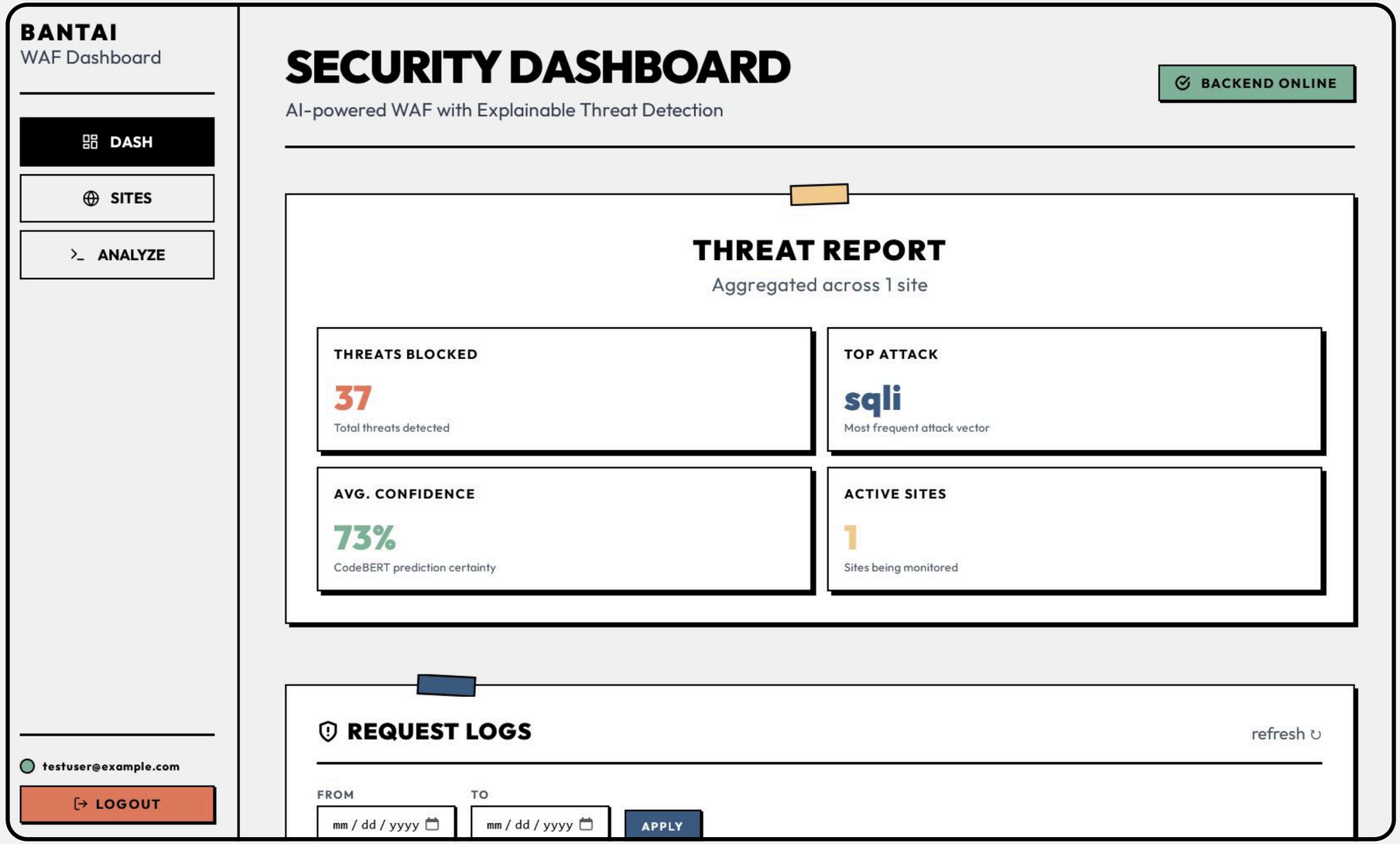
TABLE XII

PER-CLASS MDMC SCORES ($r = 0.15$)

Class	MDMC	Mean k	Mean n
cmdinj	0.3408	1.85	11.48
csrf	0.3400	4.92	33.33
ssrf	0.2335	3.67	25.00
sqli	0.2318	2.61	15.83
xss	0.1915	3.43	23.11
path-traversal	0.1255	4.74	31.21
norm	0.0950	2.86	17.25

MDMC r=0.15 · n=200 · higher = SHAP tokens drove the prediction more

Deployment



- FastAPI
- SvelteKit
- npm package

User Study — 31 CS Students

79.44
MEAN SUS SCORE — "GOOD" USABILITY (≥70)

4.62/5
PREDICTION ACCEPTABILITY

4.77/5
XAI ACCEPTABILITY

α = 0.71 (model) ; α = 0.66 (XAI)
CRONBACH'S A — HIGH INTERNAL CONSISTENCY / RELIABLE (>0.7)

reliability & correlation

MEASURE	VALUE	INTERPRETATION
Cronbach's α (model)	0.71	**Reliable Predictions**
Q4 & Q10 x SUS Spearman ρ	Q4: -0.819 Q10: -0.716	**Moderate-negative correlation**
Q4: XAI integration ease	4.52 /5	**Explanation well-integrated in UI**
Q10: Overall satisfaction	4.61 /5	Users satisfied with system
SUS ≥ 70 threshold	✓ Pass	"Good" usability band
Participants	**31**	CS students, UPLB

Q4 and Q10 both has low scores due to cybersecurity unfamiliarity.
XAI directly supports perceived usability.

BantAI works as a proof-of-concept — but needs broader improvements.

✓ **99.53%**
IN-DIST ACCURACY

× **44.66%**
EXTERNAL MACRO F1

× **45.3%**
ATTACK RECALL

★ **4.77 / 5**
XAI ACCEPTABILITY

★ **SUS 79.44**
"GOOD" USABILITY

Future Work

generalization

Domain Adaptation

Close the 44.66% external F1 gap with broader, more diverse training data across attack families.

security

Adversarial Robustness

Test against homoglyph substitutions & obfuscation attacks that bypass payload detection.

cover

CSRF / SSRF Mitigation

Add header inspection — payload-only classification has a fundamental ceiling for context-dependent attacks.

demo

BANTAI
WAF Dashboard

DASH

SITES

ANALYZE

testuser@example.com

LOGOUT

SECURITY DASHBOARD

AI-powered WAF with Explainable Threat Detection

BACKEND ONLINE

THREAT REPORT

Aggregated across 1 site

THREATS BLOCKED

37

Total threats detected

TOP ATTACK

sqli

Most frequent attack vector

AVG. CONFIDENCE

73%

CodeBERT prediction certainty

ACTIVE SITES

1

Sites being monitored

REQUEST LOGS

refresh

FROM

mm / dd / yyyy

TO

mm / dd / yyyy

APPLY